

Producción de Software

Pablo Valenzuela

4 Mayo 2026

Discusión lecturas

1. **Paper 1:** On the adoption of software bill of materials in open-source software projects
2. **Paper 2:** What We Know about AIBOMs: Results from a Multivocal Literature Review
3. **Paper 3:** If it's not SBOM, then what? How Italian Practitioners Manage the Software Supply Chain

P1: ¿Por qué, a pesar de su valor teórico, la adopción de SBOM/AIBOM sigue siendo baja en la práctica?

P1: ¿Por qué, a pesar de su valor teórico, la adopción de SBOM/AIBOM sigue siendo baja en la práctica?

- ¿Es el principal problema la falta de herramientas maduras o la falta de incentivos organizacionales?

P1: ¿Por qué, a pesar de su valor teórico, la adopción de SBOM/AIBOM sigue siendo baja en la práctica?

- ¿Es el principal problema la falta de herramientas maduras o la falta de incentivos organizacionales?
- ¿Qué rol juega el desconocimiento o la baja comprensión de regulaciones en esta baja adopción?

P2: ¿Hasta qué punto los SBOM/AIBOM realmente mejoran la seguridad de la cadena de suministro?

P2: ¿Hasta qué punto los SBOM/AIBOM realmente mejoran la seguridad de la cadena de suministro?

- ¿La información que contienen es suficiente y confiable para tomar decisiones de seguridad?

P2: ¿Hasta qué punto los SBOM/AIBOM realmente mejoran la seguridad de la cadena de suministro?

- ¿La información que contienen es suficiente y confiable para tomar decisiones de seguridad?
- ¿Qué ocurre cuando los SBOM están incompletos o desactualizados?

P3: ¿Los requisitos regulatorios están impulsando una adopción real o solo cumplimiento superficial?

P3: ¿Los requisitos regulatorios están impulsando una adopción real o solo cumplimiento superficial?

- ¿Las organizaciones adoptan SBOM/AIBOM por seguridad o por presión regulatoria?

P3: ¿Los requisitos regulatorios están impulsando una adopción real o solo cumplimiento superficial?

- ¿Las organizaciones adoptan SBOM/AIBOM por seguridad o por presión regulatoria?
- ¿Existe evidencia de cambios reales en prácticas de desarrollo o solo generación de artefactos?

P4: ¿Qué tan viable es extender SBOM hacia AIBOM en sistemas basados en IA?

P4: ¿Qué tan viable es extender SBOM hacia AIBOM en sistemas basados en IA?

- ¿Las estructuras actuales (SPDX, CycloneDX) son suficientes para capturar modelos, datos y entrenamiento?

P4: ¿Qué tan viable es extender SBOM hacia AIBOM en sistemas basados en IA?

- ¿Las estructuras actuales (SPDX, CycloneDX) son suficientes para capturar modelos, datos y entrenamiento?
- ¿Qué nuevos riesgos aparecen al intentar documentar datasets y modelos (ej. privacidad, sesgos, trazabilidad)?

Tarea 2 (11 de Mayo)

- Lectura papers 4, 5 y 6
- Extraer vulnerabilidades de los repositorios seleccionados:
 - A partir de los componentes (SBOMs)
 - Código Fuente